

Seguridad y resiliencia

Ecosistema de Automatizacion IA Autonomo · NubeFlow Consulting (caso de uso) · n8n + Airtable + Claude + Gmail

1. Minimizacion de datos

Riesgo	Control implementado
Enviar a la IA mas datos de los necesarios	Al scoring solo van cargo y mensaje (truncado a 2.000 caracteres); a la extraccion, remitente, asunto y hasta 3.000 caracteres del cuerpo; al borrador, nombre, empresa, cargo y mensaje. Nunca telefono ni el resto del correo.
PII en los registros de error	La tabla Errores guarda la descripcion tecnica y un mensaje truncado a 500 caracteres; para datos faltantes solo el nombre de los campos (por ejemplo "email"), no el contenido del formulario.
PII en alertas	Las alertas al admin incluyen remitente y asunto (o el ID de ejecucion), no el cuerpo del correo.
Correos irrelevantes	Los no relevantes (facturas, newsletters, spam) se descartan sin escribir nada en Airtable.
Exposicion del dashboard	La vista publica debe ser la Interface con KPIs agregados, no la tabla Leads (contiene emails, telefonos y razonamiento). Ver seccion 6.

2. Seguridad del prompt y de las entradas

Amenaza	Control
Inyeccion de instrucciones dentro del correo	El contenido va dentro de etiquetas (<correo>, <lead_a_evaluar>) declaradas como datos no confiables y el system prompt ordena ignorar instrucciones ahi. La IA no decide el total del score ni la categoria: solo puntua dos criterios de 0 a 20, valores que el codigo limita (clamp) y suma con reglas fijas.
Respuesta de la IA malformada	El JSON se extrae por llaves y se parsea dentro de try/catch; si no cumple el esquema, sigue la ruta de error o la alerta de correo no clasificado. Nunca se envia un email construido a partir de una salida invalida.
Prompt dinamico (sin datos fijos)	Empresa, servicio, modelos y umbrales salen del nodo Config; los datos del lead se insertan por expresion en cada ejecucion.
Tipos de dato	Nodo Normalizar convierte presupuesto y tamaño a numero; los If usan validacion estricta de tipos; Score_VIP se compara como numero y Estado como texto exacto.

3. Filtro de bucle infinito

El flujo envia correos desde la misma cuenta que lee, asi que sin control podria reprocesar sus propios mensajes. Hay tres capas:

- Consulta del trigger:** excluye promociones, redes, novedades, foros, rebotes y los asuntos de los correos del sistema ("Aprobacion requerida", "Ecosistema Leads", "Gracias por contactar").
- Nodo Filtro Anti-Bucle:** descarta cualquier correo cuyo asunto o remitente coincida con esos patrones o sea no-reply, y correos sin cuerpo.
- Deduplicacion por email en Airtable:** si un lead ya existe, se registra una nota de reingreso y no se reprocesa ni se envia nada.

Limite conocido: el email VIP redactado por la IA tiene asunto libre. Si el lead fuera la misma cuenta que lee el flujo (caso de prueba), ese correo volveria al buzón; la capa 3 lo detiene como duplicado. En producción el destinatario es externo y no vuelve a la bandeja.

4. Human-in-the-loop

Un unico punto humano, ubicado antes de la acción de mayor riesgo (escribir a un cliente potencial de alto valor): solo los leads VIP (score ≥ 80). El gerente recibe por Gmail (nodo Send & Wait, aprobación doble) el resumen, el razonamiento de la IA y **el borrador completo**, con botones Aprobar y Rechazar. Plazo: 48 horas, configurable en Config.

Resultado	Estado del lead	Decision_Humana	Que pasa
Aprueba	Aprobado_por_Humano → Completado	Aprobado	Se envia el email al lead y se registra con su Thread ID
Rechaza	Rechazado	Rechazado	No se contacta al lead
No responde en 48 h	Rechazado	Expirado	No se contacta al lead; el KPI separa rechazo de falta de respuesta

Los leads Calificado y Descarte no pasan por HITL: reciben una respuesta estandar sin contenido generado por la IA, por lo que el riesgo de un error visible para el cliente es bajo.

5. Manejo de errores y resiliencia

Falla	Deteccion	Respuesta
API de Claude (timeout, 429, 401, 5xx)	Reintentos (2 o 3 intentos, con espera) y salida de error del nodo	Registro en Errores con tipo (Timeout_API, Rate_Limit, Error_Autenticacion), lead en Error_API, alerta al admin
Respuesta de IA con formato invalido	Nodo Code lanza error, ruta de error	Registro Formato_Invalido y alerta
Airtable no crea el lead	Salida de error del nodo	Alerta directa al admin con el ID de ejecucion
Gmail no envia	Salida de error del nodo (VIP y no VIP)	Registro y alerta
Datos obligatorios faltantes (webhook)	Validacion de nombre y email antes de tocar la base	Registro Datos_Faltantes con solo el nombre de los campos y alerta
La IA no puede clasificar el correo	Bandera clasificacion_fallida	Alerta al admin con remitente y asunto; no se descarta en silencio

Todas las rutas de error de las etapas de IA y Gmail convergen en **un solo manejador** (Consolidar → Log en Airtable → Lead en Error_API → alerta), cada paso configurado para continuar aunque falle, de modo que un error del propio manejador no oculte el original. La tasa de error se calcula en Airtable (campo Con_Error) y se muestra en el dashboard.

6. Credenciales y acceso

- Las llaves (Anthropic, OAuth de Gmail y Airtable) viven solo en el gestor de credenciales de n8n; el JSON exportado las reemplaza por marcadores.

- La llave de Anthropic se usa mediante credencial Header Auth (x-api-key); no aparece en prompts, en Airtable ni en el repositorio.
- Gmail y Airtable usan OAuth2 con permisos acotados; el token de Airtable debe limitarse a esta base.
- Dashboard publico: compartir **solo la Interface** como enlace de solo lectura, o la vista de una tabla de KPIs sin campos personales. No compartir la tabla Leads.

7. Pendientes y riesgos residuales (transparencia)

- No se configuro un workflow de error global (Error Trigger); hoy los fallos dentro del flujo estan cubiertos, pero una caida completa de n8n no genera alerta. Recomendado como siguiente paso.
- Los enlaces de aprobacion de Send & Wait son URLs de reanudacion; quien las reciba puede decidir. Se envian solo al aprobador definido en Config.
- El sondeo de Gmail (1 min) puede saltarse correos si el flujo esta desactivado; no hay reproceso historico automatico.
- Los tokens de T1 y T3 no se registran aun (ver matriz de costos).